



iNeed.to

Technology · Martial Arts · Learning

DEF CON 34 · WORKSHOP

Investigating & Responding to M365 Account Compromise on a Shoestring

Living off the Land Incident Response using PowerShell and Excel – Slide Deck v1.1

PRESENTED BY

Vincent M. Weppner

HANDLE

@VinceVulpes

SITE

ineed.to

Bitpusher · The Digital Fox · theTechRelay.com · github.com/bitpusher2k



Welcome



"The criminal is the creative artist; the detective only the critic." - G.K. Chesterton

01 Who I am

Vincent M. Weppner - Senior Security Analyst at an MSP; independent consultant at theTechRelay.com. 10+ years in cybersecurity, 25+ in IT.

Dark mode > Light mode, Spaces > Tabs, 4 spaces > 2 spaces, Opening curly brace on same line > Next line.

02 Ground rules

Pair up with a neighbor when you can.

Ask questions anytime, and interrupt me if anything is unclear.

03 What this workshop IS

An introduction to BEC (M365) investigation and response; optimizing investigations with basic scripts and macros; hands-on scenarios to practice with.

04 What this workshop IS NOT

A Sentinel/KQL class. An offensive BEC / red-team class. A pen-test class.

Four-Hour Roadmap



Five modules, four hours, three scenarios, two repositories, one break...

Time	Module	Topic
0:00 - 0:30	Module 1	Introduction, threat model, training environment setup
0:30 - 1:15	Module 2	Containment & initial collection (individual scripts + Hydra sweep)
1:15 - 2:00	Module 3	Sign-in & audit log triage - Scenario 1
2:00 - 2:10	Break	10-minute break
2:10 - 3:10	Module 4	Mailbox pivoting, inbox rules, MailItemsAccessed - Scenario 2
3:10 - 3:55	Module 5	Scope expansion, remediation, hardening - Scenario 3
3:55 - 4:00	Wrap-up	Q&A, references

By the End of This Workshop



You will be able to...

- Contain an active M365 BEC incident, including the AD-sync password-writeback edge cases.
- Retrieve the right M365 logs at the right licensing tier via admin center or PowerShell.
- Normalize, flatten, and enrich raw CSV log exports for rapid manual review in Excel.
- Identify suspicious sign-ins by geolocation, ASN, device, OS, user agent, MFA status.
- Detect and remediate malicious inbox rules (the #1 BEC persistence mechanism).
- Pivot through logs by chronology and topology to expand investigation scope.
- Determine what mail and files were accessed, within the limits of your licensing.
- Recognize malicious OAuth apps (PerfectData, eM Client, others) and revoke consent.
- Produce an investigation report, attestation letter, and internal post-mortem.
- Apply hardening with Conditional Access, phishing-resistant MFA, and Secure Score.

Throughout: build practical instincts, and reduce dependence on tools, guides, or AI.

Why BEC, M365, LOtL?



"We have done so much, for so long, with so little, we are now qualified to do anything with nothing." - K.J. Jireček

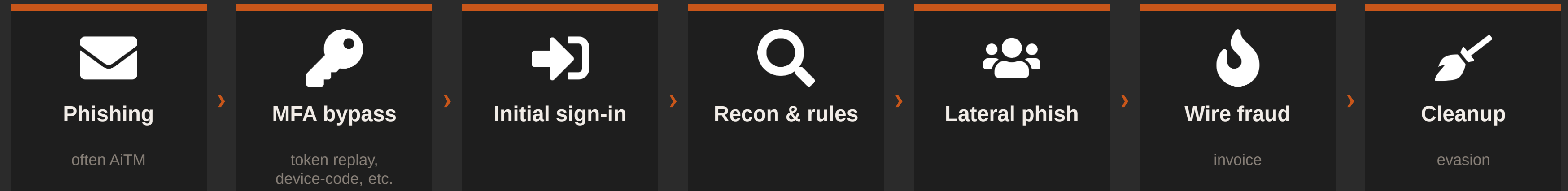
- BEC is one of the highest-loss cybercrime categories tracked by the FBI IC3 (\$8.5B from 2022-2024 - [FBI's IC3 Finds Almost \\$8.5 Billion Lost to Business Email Compromise in Last Three Years | Nacha](#)). \$16.6B total internet-crime losses in 2024 - a new record ([FBI: Cybercrime Losses Surpassed \\$16.6 Billion in 2024 – SecurityWeek, FBI Releases Annual Internet Crime Report — FBI](#)).
- Microsoft 365 tenants are the dominant target environment.
- Many SMB/SME responders face these incidents without optimal tooling.
- Respond with only native PowerShell and a spreadsheet. No Sentinel or other SIEM.
- Assume lower licensing tiers (often Entra ID Free).
- Greatest IR tools: shell scripts, spreadsheets, and your mind - always available, broadly applicable.
- If you have more capable tooling, use it.
- I.A.N.A.L. - none of this is legal advice. For legal advice, talk to a lawyer.

A defender's perspective on what happens after the phish lands, and how to respond with minimal tooling.

Anatomy of a Modern M365 BEC



What do the threat actors want? Where is the evidence located?



WHERE THE DEFENDER'S SIGNAL LIVES

- Entra ID Sign-In Logs (interactive + non-interactive) · Entra ID Audit Logs · Unified Audit Log (UAL)
- Mailbox audit logs (now rolled into the UAL) · Exchange message trace · Microsoft Defender alerts & incidents
- Entra ID risk detections · Tenant / mailbox configuration state

Licensing Reality



Current paywalling of security features in the M365 environment

Source	Basic / Standard	Premium / E3	E5 / Defender P2
Unified Audit Log	180 days	180 days	1 year (365d)
Entra Sign-In Logs	7 days (Free)	30 days (P1)	30 days (P1/P2)
MailItemsAccessed	Limited / throttled	Available	Available + detailed
Mailbox audit (default)	Enabled	Enabled	Enabled + extended
Entra Risk Detections	Not available	Basic (P1)	Full (P2)
Conditional Access	Security Defaults	Full CA (P1)	CA + risk-based (P2)

Figures approximate and subject to change by Microsoft. Verify against current docs.

learn.microsoft.com/entra/identity/monitoring-health/reference-reports-data-retention · learn.microsoft.com/purview/audit-log-retention-policies

Training Environment Verification



LIVE LAB TENANT (OPTIONAL FOR FULLY TESTING SCRIPTS)

- PowerShell 7.x + ExchangeOnlineManagement, Microsoft.Graph, Microsoft.Graph.Beta
- Clone the M365IRScripts repo
- Run "00-Update-M365Modules.ps1"
- Run "01-Connect-M365Modules.ps1" -ReadOnly
(read-only investigator account)
- Run "10-Get-BasicTenantInformation.ps1" to verify

SCENARIO DATASETS (LOCAL LOGS TO REVIEW)

- Windows 11 + PowerShell 7 recommended
- Extract the sample-datasets bundles (repo or USB)
- Open the pre-exported 10-Get-BasicTenantInformation output
- Run processing scripts (02, 03, 05, 06) against the CSVs
- Deterministic from pre-exported logs - no network needed

"All characters appearing in this work are fictitious. Any resemblance to real persons, living or dead, is purely coincidental"

Common gotchas: TLS 1.2 enforcement · Stale module paths · CA blocking PowerShell sign-in · Graph consent prompts · Module conflicts.

02

MODULE 2 • 0:30 – 1:15 • 45 minutes • Lecture + Hands-on

Containment & Initial Collection



You Received an Alert - Contain or Observe?



CONTAIN NOW

- Compromise confirmed by user or evidence
- Active wire fraud in progress
- Admin role compromise suspected
- Lateral phishing already underway
- Regulatory clock already running
- Sensitive-data access with evidence of mass read

OBSERVE FIRST (CAUTIOUSLY)

- Threat already contained by circumstance (password rotated)
- Cannot confirm compromise, and containment may harm end users

When in doubt, contain. Usually better to err on the side of containment.

Reset Password, Revoke Sessions, Block Sign-In



When your password reset appears to work - and doesn't

Edit properties

Delete

Refresh

Reset password

Revoke sessions

Manage view

Got feedback?

Overview

Monitoring

Properties

Basic info

Adele Vance

AdeleV@854jpt.onmicrosoft.com

Member

Revoke sessions

Immediately terminate all active access and tokens.

Reset password

So the attacker cannot log back in with old credentials.

Block sign-in (optional)

Freeze the account while you scope the breach.

Adele Vance

Reset password

Block sign-in

Delete user

[Change photo](#)

Account

Devices

Licenses and apps

Mail

OneDrive

Sign-out ⓘ

Sign this user out of all Microsoft 365 sessions.

[Sign out of all sessions](#)

Entra ID and AD-Sync



IF WRITEBACK IS NOT ENABLED

The gotcha

- Disable-MgUser / Set-MgUserPassword appear to succeed
- Entra re-syncs the old password and re-enables next cycle
- Change the password in on-prem AD first
- Force a sync: Start-ADSyncSyncCycle -PolicyType Delta
- THEN revoke sessions and block sign-in in Entra ID

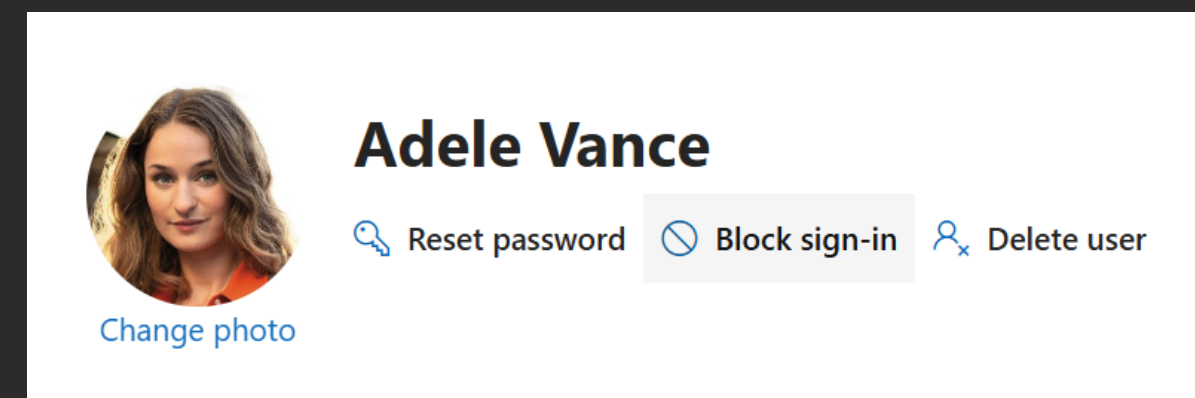
```
Administrator: Windows PowerShell
PS C:\> Start-ADSyncSyncCycle -PolicyType Delta

Result
-----
Success
```

IF WRITEBACK IS ENABLED

Still verify

- Reset from Entra ID and it propagates down
- Confirm the account reaches Disabled in both directories
- Some environments have writeback configured but broken
- Test, don't assume



Verify the account shows disabled in both AD and Entra ID after sync.

25-Lockdown-Account.ps1 - Under the Hood



Three things the script does, and why each matters independently

01 Revoke sessions

```
Revoke-MgUserSignInSession
```

Invalidates all existing access and refresh tokens. Without this, a stolen token keeps working until it expires, even after a password reset.

02 Block sign-in

```
Update-MgUser -AccountEnabled:$false
```

Stops any future interactive sign-in attempt.

03 Force password reset

```
Update-MgUser -ForceChangePasswordNextSignIn
```

A password change alone is insufficient without step 1; the account reopens without step 3 on 2-reversal.

```
PS> .\25-Lockdown-Account.ps1 -UserPrincipalName user@client.com -RevokeSessions -BlockSignIn -ResetPassword
```


Initial Log Collection – Basic Information, Scripts



MANUAL COLLECTION

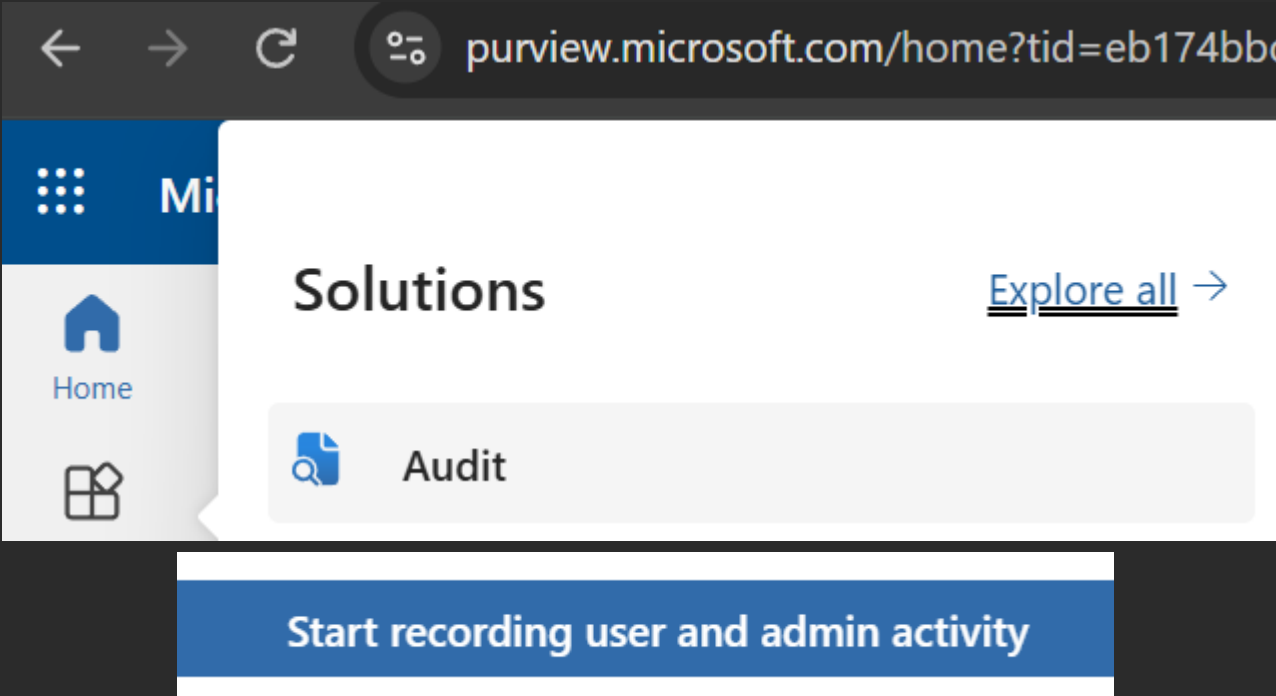
- Check license, user count, and user information
- Verify user roles
- Review Exchange Online configuration
- Confirm what the admin center exposes at this tier
- Note the tenant's baseline before you dig in

Critical: UAL must be enabled before the incident. Investigation depends on what the provider logged.
Connect-ExchangeOnline -DisableWAM ; Enable-OrganizationCustomization ;
Get-OrganizationConfig | Format-List IsDehydrated ; Set-AdminAuditLogConfig -UnifiedAuditLogIngestionEnabled \$true

Basic information			
Name	MSFT	Users	18
Tenant ID	eb174bbc-fe94-4978-95b9-a616457dd489 	Groups	7
Primary domain	854jpt.onmicrosoft.com	Applications	0
License	Microsoft Entra ID P2	Devices	0

SCRIPTED COLLECTION

- Start collecting logs at the start – Can take a while
- Each script can run independently – one error won't stop the rest
- Output goes to an Investigation folder, one sub-folder per tenant



M365 Access & Roles for Response



Least-privilege roles the investigator actually needs

01 Containment actions

Entra: User Administrator / Authentication Administrator

Reset passwords, revoke sessions, force sign-out, block sign-in. Privileged Authentication Administrator is required to reset admin accounts.

02 Log & mailbox collection

Global Reader / Security Reader · Exchange Compliance Management, Help Desk

Read UAL, sign-in and audit logs, mailbox settings, inbox rules, and forwarding with minimal write access.

☒

Admin center access

Global readers have read-only access to the admin center. Other roles are more limited in what they can do.

☒

Global Reader ⓘ

☒

Security Reader ⓘ

03 Search & purge

Purview: eDiscovery Manager / eDiscovery Administrator

Run Content Search, preview, export, and purge phishing tenant-wide. Held separately from investigation read roles.

04 Graph tools admin consent

Entra admin center > Enterprise apps > "Microsoft Graph Command Line Tools" > Permissions > "Grant admin consent for ..."

Or – Connect-MgGraph string from 01 script using Admin account to grant consent.

Home > Enterprise applications | All applications > Microsoft Graph Command Line Tools

Microsoft Graph Command Line Tools | Permissions

Enterprise Application

Overview

Deployment Plan

Diagnose and solve problems

Manage

Properties

Owners

Roles and administrators

Review permissions

Refresh

Got feedback?

Permissions

Below is the list of permissions that have been granted for your organization. A permission is granted directly to this app (app permissions).

[Learn more](#)

You can review, revoke, and restore permissions.

[Learn more](#)

Grant admin consent for MSFT

Prefer a dedicated read-only investigator account. Escalate to write roles only for the specific step. In reality often running from Global Admin.

iNeed.to

DEF CON 34 · Living off the Land IR: M365 BEC

15

The Hydra Sweep



Preserve logs at the start, before threat-actor cleanup and before retention rolls off

Connect



Collect logs



One folder / tenant



Analyze



**Run targeted
scripts**

```
PS> .\09-Hydra-Collect.ps1 `
    -OutputFolder .\Investigation `
    -DaysBack 10
```

```
PS> .\09-Hydra-Collect.ps1 `
    -OutputFolder .\Investigation `
    -DaysBack 10 `
    -ReadOnly
```

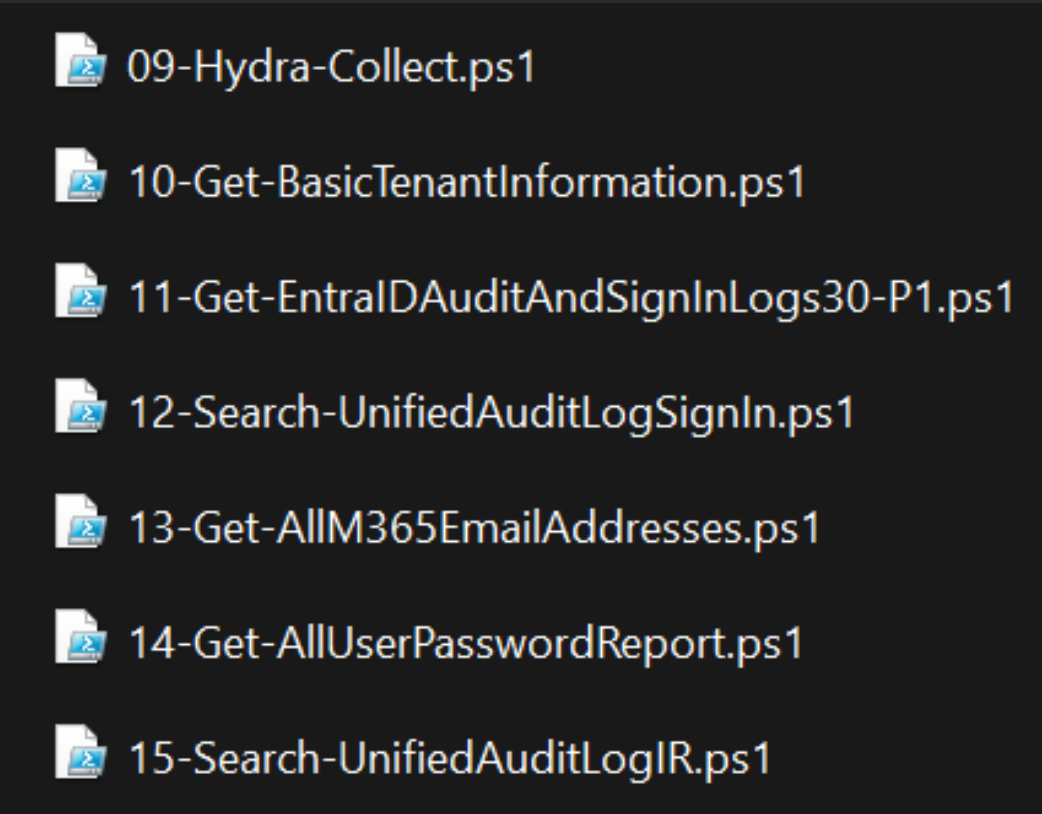
Critical: UAL must be enabled before the incident. Expected runtime 5-15 min by tenant size.

What Hydra Collects



Each script is a small, focused, independent task

- 10-Get-BasicTenantInformation - tenant name, licensing, UAL-enabled flag
- 13/14 - email address and password-report inventory snapshot
- 17/18/19 - inbox-rule persistence artifacts (captured first and last)
- 20/21 - forwarding settings and mailbox-permission exfil artifacts
- 22-Get-EnterpriseApplications - OAuth grants, including known-bad apps
- 23/24 - Defender information and Entra ID risk detections
- 90/91/93 - MFA, Conditional Access, and Secure Score posture
- 11-Get-EntraIDAuditAndSignInLogs30-P1 - 30 days of Entra sign-in + audit
- 12-Search-UnifiedAuditLogSignIn - UAL sign-ins (180+ day retention)
- Optional: Invictus Extractor Suite, CrowdStrike CRT



09-Hydra-Collect.ps1

10-Get-BasicTenantInformation.ps1

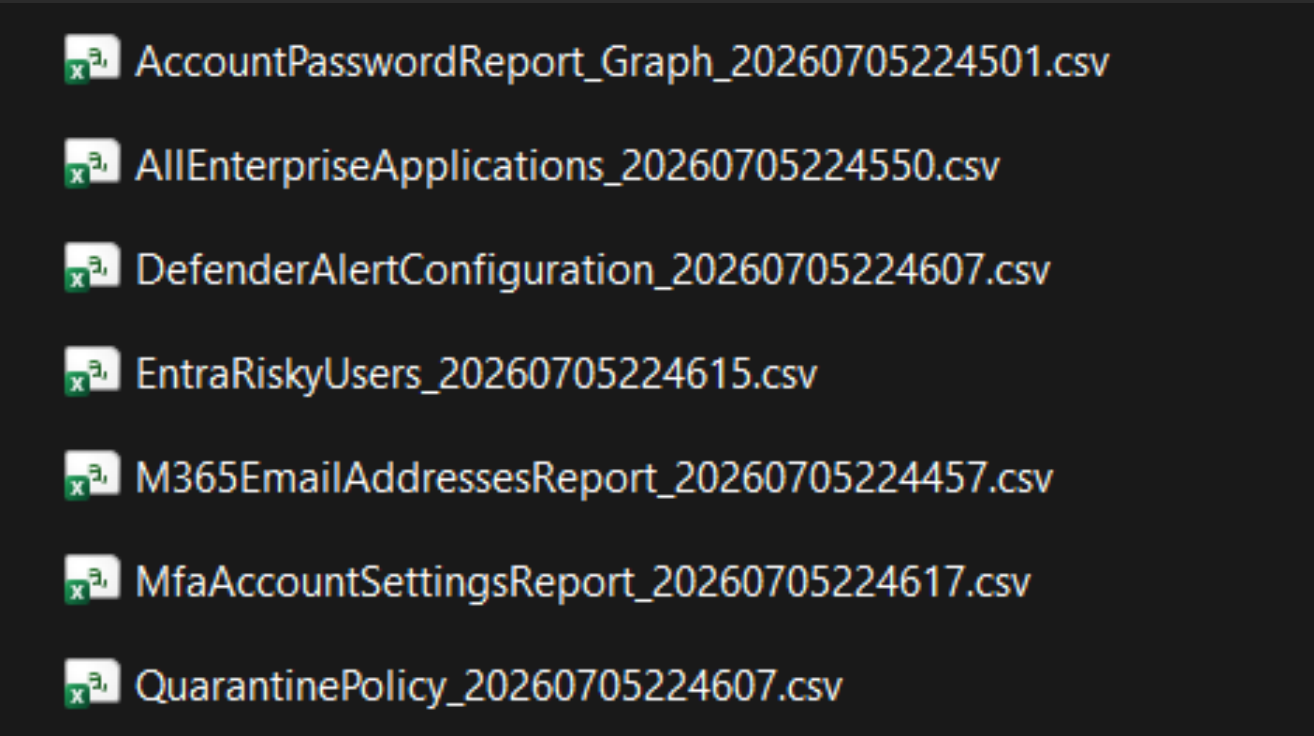
11-Get-EntraIDAuditAndSignInLogs30-P1.ps1

12-Search-UnifiedAuditLogSignIn.ps1

13-Get-AllM365EmailAddresses.ps1

14-Get-AllUserPasswordReport.ps1

15-Search-UnifiedAuditLogIR.ps1



AccountPasswordReport_Graph_20260705224501.csv

AllEnterpriseApplications_20260705224550.csv

DefenderAlertConfiguration_20260705224607.csv

EntraRiskyUsers_20260705224615.csv

M365EmailAddressesReport_20260705224457.csv

MfaAccountSettingsReport_20260705224617.csv

QuarantinePolicy_20260705224607.csv

Deliverable: every attendee has a populated Investigation\<tenant>\ folder ready to analyze.

03

MODULE 3 • 1:15 – 2:00 • 45 minutes • Scenario category 1 • Sign-in/Audit logs

Sign-In & Audit Log Triage



Retrieving Sign-In Logs on Entra ID (Free)



No PowerShell sign-in log API below P1, so use the portal

01 Why the GUI

`Get-MgAuditLogSignIn` requires Entra ID P1/P2

On the Free tier the sign-in log Graph endpoint is unavailable, and retention is only 7 days. The portal is the only export path.

02 Where

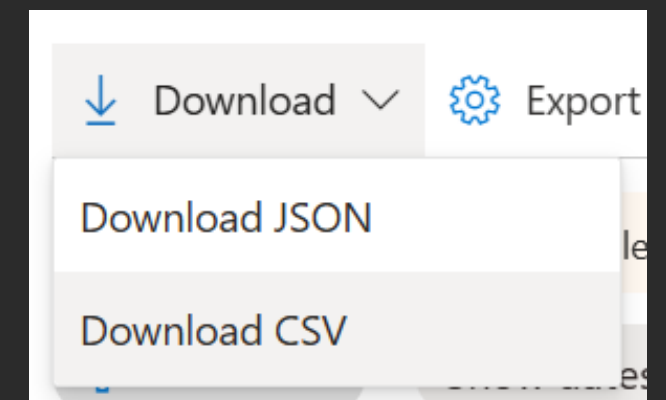
`entra.microsoft.com > Monitoring & health > Sign-in logs` (or `portal.azure.com > Entra ID > Monitoring > Sign-in logs`)

Filter by user and date range. From sign-ins preview changing column set has not been seen to change CSV export.

03 Export

`Download > JSON or CSV` (for our purposes today, CSV)

JSON preserves nested fields the CSV flattens poorly. Feed either into 02-ProcessEntraSignInLog.ps1 for normalization.



Seven-day retention on Free is unforgiving. Pull sign-in logs first, before anything rolls off.

The Sign-In Log Pipeline



Raw CSV, normalized, enriched, filtered in Excel



```
SignInLog.csv          > drag onto > 02-ProcessEntraSignInLog.bat  > SignInLog-Processed.csv
SignInLog-Processed    > drag onto > 06-Lookup-IPInfoCSV.bat        > ...-IPInfo.csv
Open enriched CSV in Excel. Load ExcelMacros in personal workbook.
```

Sign-In Log: Notable Fields



The columns that carry the signal after processing

01 Identity & session

UserPrincipalName · SessionId · CorrelationId · AuthRequirement · JoinType

SessionId ties every action in one login together.

02 Network & location

IPAddress · ASN / ISP · City / Region / Country · Latency · Third-party score/IP range/Org

Enriched by 06-Lookup-IPInfoCSV.ps1. Cloud/VPS ASNs and impossible-travel geography are the loudest signals.

03 Device & auth

OS · Browser / UserAgent · Application · Status · MFA result

'Satisfied by claim in token', axios or python user agents, and unregistered devices flag AiTM sessions.

One field may not be enough. Filter on one suspect trait, then confirm it with the others.

Suspicious Sign-In Traits



Correlate as many as possible; one alone is often inconclusive

Time

Unusual hours for this user. Impossible travel (two geos, short gap).

Geolocation

Distant or high-risk country the user has no history with.

ISP / ASN

Cloud-hosting ASN (DigitalOcean, OVH, Linode). VPN/VPS reputation.

Device

Unregistered device. New device ID correlated to a suspect IP.

OS / user agent

axios, python-httpx, curl, generic Mozilla. Unusual OS.

MFA

'Satisfied by claim in token' (AiTM fingerprint). Single factor / bypass.

Correlation is not causation, but you have to start somewhere. Pivot from one trait to find the others.

Scenario 1 - Sign-In Log Excerpt



What you are looking at in the CSV you just enriched

A	D	E	F	G	H	I	J	K	L	M	N	O	P
DateUTC	User	Username	IPAddress	City	Region	Count	Status	SignInErrorCo	UserTy	AuthRequirement	ConditionalAcce	TokenType	Application
2025-10-30T23:26:24Z	Allen White	allen.white@acme.com	2600:1700:89d0:315b:ebbf:74c4:60ba:b261	Kestrel 6	East Province 2	US	Success		member	Single-factor authentication	Success	primaryRefreshToken	Office365 Shell WCSS-Client
2025-10-30T23:22:14Z	Victoria1 Heather3	victoria1.heather3@acme.com	70.168.253.125	Bridgeport	East Province 2	US	Success		member	Single-factor authentication	Success	primaryRefreshToken	Microsoft Account Controls V2
2025-10-30T23:22:12Z	Victoria1 Heather3	victoria1.heather3@acme.com	70.168.253.125	Bridgeport	East Province 2	US	Success		member	Single-factor authentication	Success	primaryRefreshToken	My Profile
2025-10-30T23:21:59Z	Victoria1 Heather3	victoria1.heather3@acme.com	70.168.253.125	Bridgeport	East Province 2	US	Success		member	Single-factor authentication	Success	primaryRefreshToken	OfficeHome
2025-10-30T23:21:27Z	Allen White	allen.white@acme.com	2600:1700:89d0:315b:ebbf:74c4:60ba:b261	Kestrel 6	East Province 2	US	Success		member	Single-factor authentication	Success	primaryRefreshToken	Office 365 Exchange Online
2025-10-30T23:20:30Z	Victoria1 Heather3	victoria1.heather3@acme.com	2a0d:5600:8:29a8:3d69:8ceb:df66:251c	Garrison 2	West Province 4	US	Success		member	Single-factor authentication	Success	none	OfficeHome
2025-10-30T23:20:30Z	Victoria1 Heather3	victoria1.heather3@acme.com	2a0d:5600:8:29a8:3d69:8ceb:df66:251c			US	Interrupted	50140	member	Single-factor authentication	Success	none	OfficeHome
2025-10-30T23:19:57Z	Victoria1 Heather3	victoria1.heather3@acme.com	2a0d:5600:8:9bbc:171d:77b3:c6ca:2351			US	Success		member	Single-factor authentication	Success	none	OfficeHome
2025-10-30T23:19:57Z	Victoria1 Heather3	victoria1.heather3@acme.com	2a0d:5600:8:9bbc:171d:77b3:c6ca:2351			US	Interrupted	50140	member	Single-factor authentication	Success	none	OfficeHome
2025-10-30T23:18:34Z	Victoria1 Heather3	victoria1.heather3@acme.com	2c0f:2a80:14:7ea2:7c04:99ad:8833:1a1			NG	Success		member	Single-factor authentication	Success	none	One Outlook Web
2025-10-30T23:18:01Z	Victoria1 Heather3	victoria1.heather3@acme.com	2c0f:2a80:14:7ea2:7c04:99ad:8833:1a1			NG	Success		member	Single-factor authentication	Success	none	OfficeHome
2025-10-30T23:17:59Z	Victoria1 Heather3	victoria1.heather3@acme.com	2c0f:2a80:14:7ea2:7c04:99ad:8833:1a1			NG	Success		member	Single-factor authentication	Success	none	OfficeHome
2025-10-30T23:17:58Z	Victoria1 Heather3	victoria1.heather3@acme.com	2a0d:5600:8:29a8:3d69:8ceb:df66:251c			US	Success		member	Single-factor authentication	Success	none	OfficeHome
2025-10-30T23:17:58Z	Victoria1 Heather3	victoria1.heather3@acme.com	2a0d:5600:8:29a8:3d69:8ceb:df66:251c			US	Interrupted	50140	member	Single-factor authentication	Success	none	OfficeHome
2025-10-30T23:17:11Z	Victoria1 Heather3	victoria1.heather3@acme.com	2a0d:5600:8:9bbc:171d:77b3:c6ca:2351			US	Success		member	Single-factor authentication	Success	none	OfficeHome
2025-10-30T23:17:11Z	Victoria1 Heather3	victoria1.heather3@acme.com	2a0d:5600:8:9bbc:171d:77b3:c6ca:2351			US	Interrupted	50140	member	Single-factor authentication	Success	none	OfficeHome
2025-10-30T23:10:10Z	Torres1 Joyce	torres1.joyce@acme.com	70.168.253.125	Bridgeport	East Province 2	US	Success		member	Multifactor authentication	Success	none	SharePoint Online Web Client Extensibility
2025-10-30T23:06:58Z	Richard Nancy1	richard.nancy1@acme.com	72.219.171.58	Linden 3	East Province 2	US	Success		member	Multifactor authentication	Success	none	One Outlook Web
2025-10-30T22:57:13Z	Jackson1 angela1 Morg	nancy.baker2@acme.com	104.34.3.180	Ashford 1	East Province 2	US	Success		member	Single-factor authentication	Success	primaryRefreshToken	Office365 Shell WCSS-Client
2025-10-30T22:57:01Z	Jackson1 angela1 Morg	nancy.baker2@acme.com	104.34.3.180	Ashford 1	East Province 2	US	Success		member	Single-factor authentication	Success	primaryRefreshToken	SharePoint Online Web Client Extensibility
2025-10-30T22:57:00Z	Jackson1 angela1 Morg	nancy.baker2@acme.com	104.34.3.180	Ashford 1	East Province 2	US	Success		member	Single-factor authentication	Success	primaryRefreshToken	SharePoint Online Web Client Extensibility
2025-10-30T22:56:55Z	Jackson1 angela1 Morg	nancy.baker2@acme.com	104.34.3.180	Ashford 1	East Province 2	US	Success		member	Single-factor authentication	Success	primaryRefreshToken	Office 365 SharePoint Online
2025-10-30T22:53:55Z	Ruth Perez1	ruth.perez1@acme.com	2600:4040:b297:23b3:9937:b724:532:33d8	Riverton 5	Coastal Region 7	US	Success		member	Single-factor authentication	Not Applied	primaryRefreshToken	Windows Sign In
2025-10-30T22:44:34Z	Sandra2 Sandra3	sandra2.sandra3@acme.com	47.147.123.152	Vandalia 1	East Province 2	US	Success		member	Single-factor authentication	Success	primaryRefreshToken	SharePoint Online Web Client Extensibility
2025-10-30T22:44:11Z	Sandra2 Sandra3	sandra2.sandra3@acme.com	47.147.123.152	Vandalia 1	East Province 2	US	Success		member	Single-factor authentication	Success	primaryRefreshToken	Office365 Shell WCSS-Client
2025-10-30T22:40:13Z	Sandra2 Sandra3	sandra2.sandra3@acme.com	47.147.123.152	Vandalia 1	East Province 2	US	Success		member	Single-factor authentication	Success	primaryRefreshToken	Office365 Shell WCSS-Client
2025-10-30T22:36:03Z	Victoria1 Heather3	victoria1.heather3@acme.com	70.168.253.125	Bridgeport	East Province 2	US	Success		member	Single-factor authentication	Success	primaryRefreshToken	Office365 Shell WCSS-Client
2025-10-30T22:32:25Z	Torres1 Joyce	torres1.joyce@acme.com	70.168.253.125	Bridgeport	East Province 2	US	Success		member	Multifactor authentication	Success	none	Office 365 SharePoint Online
2025-10-30T22:27:30Z	Sandra2 Sandra3	sandra2.sandra3@acme.com	47.147.123.152	Vandalia 1	East Province 2	US	Success		member	Single-factor authentication	Success	none	Office365 Shell WCSS-Client
2025-10-30T22:27:21Z	Sandra2 Sandra3	sandra2.sandra3@acme.com	47.147.123.152	Vandalia 1	East Province 2	US	Success		member	Single-factor authentication	Success	none	Office365 Shell WCSS-Client
2025-10-30T22:26:41Z	Sandra2 Sandra3	sandra2.sandra3@acme.com	47.147.123.152	Vandalia 1	East Province 2	US	Success		member	Single-factor authentication	Success	none	Office365 Shell WCSS-Client
2025-10-30T22:26:35Z	Sandra2 Sandra3	sandra2.sandra3@acme.com	47.147.123.152	Vandalia 1	East Province 2	US	Success		member	Single-factor authentication	Success	none	SharePoint Online Web Client Extensibility
2025-10-30T22:23:46Z	Hughes2 Betty1	hughes2.betty1@acme.com	159.83.123.245	Stonebridge 3	East Province 2	US	Success		member	Single-factor authentication	Not Applied	primaryRefreshToken	Windows Sign In
2025-10-30T22:13:02Z	Allen1 Hughes1	allen1.hughes1@acme.com	2603:9008:22f0:5d2a:1a3c:f272:de22:7a55	Pinehurst	East Province 2	US	Success		guest	Multifactor authentication	Not Applied	primaryRefreshToken	SharePoint Online Web Client Extensibility
2025-10-30T22:12:44Z	Allen1 Hughes1	allen1.hughes1@acme.com	2603:9008:22f0:5d2a:1a3c:f272:de22:7a55	Pinehurst	East Province 2	US	Success		guest	Multifactor authentication	Not Applied	primaryRefreshToken	Office 365 SharePoint Online

- Malicious IP(s)

Record in incident notes. Note ASN.
- SessionID(s)

You will pivot on these in Module 4.
- Time window

First to last suspect sign-in.
- Baseline deviations

Which trait(s) flagged this?

When Sign-In Logs Run Out: The UAL



Overcoming 7 to 30 day sign-in retention with the 180+ day UAL

01 The limit

`Entra sign-in logs: 7 days (Free) / 30 days (P1/P2)`

By the time many BEC cases surface, the interactive sign-in window has already rolled off.

02 The workaround

`12-Search-UnifiedAuditLogSignIn.ps1`

The UAL records UserLoggedIn / UserLoginFailed for 180 days (E3 / Business) up to 1 year (E5), well past the sign-in log window.

03 The tradeoff

`Fewer fields, more latency`

UAL sign-in events lack some device and CA detail and can lag hours behind. Re-query later and de-duplicate. Post-processing enrichment more important.

When the sign-in log is empty, the UAL still remembers. Always check both.

Your Turn - Exercise 3.1



Find the threat actor in Scenario 1.2

DELIVERABLE

- The malicious IP address(es)
- The SessionID(s) they used
- The timestamp range of presence (first to last)
- Which suspicious traits flagged them (all that apply)

HINTS

- IP frequency: attacker IPs appear less often than legit user IPs (frequency macro)
- Residential ISPs are rarely attacker infra; cloud/VPN/server ranges are suspect
- 'Satisfied by claim in token' outside the user's pattern is highly suspect
- Don't over-count. Let multiple traits align

Work with your neighbor. 20 minutes on the clock. Raise a hand if stuck.

Now Correlate the Audit Log



What did the threat actor DO to account settings once they got in?

Authentication method added

Classic persistence - they want MFA that they control.

OAuth application consent granted

App with read-mailbox or full access. See PerfectData, eM Client.

Password change

Could be the user; could be the attacker locking them out.

Role assignment

Red-alert if Global Admin. Scope just expanded massively.

Deliverable: a short incident timeline (one row per suspect event) in your spreadsheet.

Scenario 1 - Audit Log Excerpt



Events to correlate against the malicious sign-in window

A	B	I	M	T	V	Y	Z	AA	AF
ActivityDateTim	ActivityDisplayName	Category	InitiatedBy.App.DisplayName	InitiatedBy.User.IPAddress	InitiatedBy.User.UserPrincipalName	LoggedByService	OperationTy	Result	TargetResources.1.ModifiedPropert
2025-11-01 00:07	Update StsRefreshTokenValidFrom Timestamp	UserManagement		20.190.152.187	admin@acme.onmicrosoft.com	Core Directory	Update	success	
2025-11-01 00:07	Reset user password	UserManagement		20.190.152.187	admin@acme.onmicrosoft.com	Core Directory	Update	success	
2025-11-01 00:07	Update PasswordProfile	UserManagement		20.190.152.187	admin@acme.onmicrosoft.com	Core Directory	Update	success	ForceChangePassword
2025-11-01 00:07	Update user	UserManagement		20.190.152.187	admin@acme.onmicrosoft.com	Core Directory	Update	success	StsRefreshTokensValidFrom
2025-11-01 00:07	Update PasswordProfile	UserManagement		20.190.152.187	admin@acme.onmicrosoft.com	Core Directory	Update	success	ForceChangePassword
2025-10-30 23:42	Synchronization rule action	ProvisioningManagement	Azure AD Cloud Sync			Account Provisioning	Read	success	
2025-10-30 23:42	Synchronization rule action	ProvisioningManagement	Azure AD Cloud Sync			Account Provisioning	Read	success	objectId
2025-10-30 23:42	Export	ProvisioningManagement	Azure AD Cloud Sync			Account Provisioning	Read	success	active
2025-10-30 23:42	Import	ProvisioningManagement	Azure AD Cloud Sync			Account Provisioning	Read	success	active
2025-10-30 23:42	Other	ProvisioningManagement	Azure AD Cloud Sync			Account Provisioning	Read	success	active
2025-10-30 23:42	Import	ProvisioningManagement	Azure AD Cloud Sync			Account Provisioning	Read	success	objectId
2025-10-30 23:40	Update StsRefreshTokenValidFrom Timestamp	UserManagement		20.190.151.24	admin@acme.onmicrosoft.com	Core Directory	Update	success	
2025-10-30 23:40	Reset user password	UserManagement		20.190.151.24	admin@acme.onmicrosoft.com	Core Directory	Update	success	
2025-10-30 23:40	Update PasswordProfile	UserManagement		20.190.151.24	admin@acme.onmicrosoft.com	Core Directory	Update	success	ForceChangePassword
2025-10-30 23:40	Update user	UserManagement		20.190.151.24	admin@acme.onmicrosoft.com	Core Directory	Update	success	StsRefreshTokensValidFrom
2025-10-30 23:40	Update PasswordProfile	UserManagement		20.190.151.24	admin@acme.onmicrosoft.com	Core Directory	Update	success	ForceChangePassword
2025-10-30 23:40	Update user	UserManagement	Pia.CustomerPortal.Tenant.Prod.185.Consent			Core Directory	Update	success	AccountEnabled
2025-10-30 23:40	Enable account	UserManagement	Pia.CustomerPortal.Tenant.Prod.185.Consent			Core Directory	Update	success	AccountEnabled
2025-10-30 23:33	Import	ProvisioningManagement	Azure AD Cloud Sync			Account Provisioning	Read	success	active
2025-10-30 23:33	Other	ProvisioningManagement	Azure AD Cloud Sync			Account Provisioning	Read	success	active
2025-10-30 23:22	Update user	UserManagement	Radius Aad Syncer			Core Directory	Update	success	AccountEnabled
2025-10-30 23:22	Disable account	UserManagement	Radius Aad Syncer			Core Directory	Update	success	AccountEnabled
2025-10-30 23:22	Update user	UserManagement	Radius Aad Syncer			Core Directory	Update	success	StsRefreshTokensValidFrom
2025-10-30 23:22	Update StsRefreshTokenValidFrom Timestamp	UserManagement	Radius Aad Syncer			Core Directory	Update	success	StsRefreshTokensValidFrom
2025-10-30 23:22	Settings_GetSettingsAsync	GroupManagement		20.228.63.31	victoria1.heather3@acme.com	Self-service Group Management	Update	success	
2025-10-30 23:22	Settings_GetSettingsAsync	GroupManagement		4.154.168.188	victoria1.heather3@acme.com	Self-service Group Management	Update	success	
2025-10-26 11:04	Self-service password reset flow activity progress	UserManagement		2a02:c206:2154:ca6:6eab:591b:1adb:6de6	victoria1.heather3@acme.com	Self-service Password Management	Update	success	
2025-10-26 11:04	Self-service password reset flow activity progress	UserManagement		2a02:c206:2154:ca6:6eab:591b:1adb:6de6	victoria1.heather3@acme.com	Self-service Password Management	Update	success	
2025-10-23 18:20	Update user	UserManagement	Microsoft Substrate Management			Core Directory	Update	success	Included Updated Properties

Auth method added

From the suspect IP.

OAuth consent

'PerfectData Software'.

No role change

Scope stays at one account for now.

No password change

The user's credentials still work.

04

MODULE 4 · 2:10 – 3:10 · 60 minutes · Scenario 2 · Sign-in/Audit/Inbox rule/UAL

Mailbox Pivoting, Inbox Rules, MIA



Why Inbox Rules Are the BEC #1



They survive resets, they are invisible to the user, they do the attacker's work

Survive password resets

Rules live at the mailbox, not the credential. A reset does not remove them.

Invisible to the user

Rule lists are rarely reviewed. Outlook hides them three menus deep.

Filter specific senders

From the CFO, about invoices - move to folder, mark read.

Delete evidence in real time

Move to Deleted Items, hide in RSS. The user may never see it.

Forward externally

Forward-as-attachment to an attacker mailbox. Exfil by the mail system itself.

Run 24/7

No log-in, no session, no alert. The rule fires on every inbound message.

Heuristics in 17-Search-MailboxSuspiciousRules.ps1: odd rule names, external forward, move-to-RSS, finance keywords, silent delete.

Malicious Inbox Rules



Find them, understand the intent, remove them

A	B	C	D	E	F	G	H	I	J
SuspectTrait	DisplayName	PrimarySmtpAddress	RuleName	RulePrior	RuleIdentity	RuleDescription	RuleEnabl	RuleForwardTo	
MessageForwarding	Donna18 Betty12	donna18@contoso.com	Successful or unsuccessful fax	4	9124926408680800257	If the message: the message was received from 'edward48@cruz2926.example' and the message was sent to 'Donna18 Betty12'	FALSE	"Betty12 Support"	
RuleName	Betty20 Deborah51	betty20@contoso.com	...	2	2298125932252102657	Take the following actions: mark the message as Read and move the message to folder 'RSS Feeds' and stop cooper26 more rules on this message	FALSE		
MessageMoveFolder	Betty20 Deborah51	betty20@contoso.com	support	1	10512691652575887361	If the message: the message was received from 'sandra48@freemail2.example' or 'carter24@cruz29107.example' or	TRUE		
RuleName	Betty20 Deborah51	betty20@contoso.com	...	2	2298125932252102657	Take the following actions: mark the message as Read and move the message to folder 'RSS Feeds' and stop cooper26 more rules on this message	FALSE		
MessageDeletion	Ramos24 Nelson15	taylor32@contoso.com	Jambor, Kathy M	1	7789179622452625409	If the message: the message was received from 'Jambor, Kathy M' Take the following actions: delete the message	TRUE		
MessageDeletion	Ramos24 Nelson15	taylor32@contoso.com	anthony35@cruz29110.example	3	7933294810528481281	If the message: the message was received from 'anthony35@cruz29110.example' Take the following actions:	TRUE		
MessageDeletion	Ramos24 Kimberly21	ramos24@contoso.com	Redirect messages sent to ramos24@cruz2976.example	1	4346819594502012929	If the message: the message was sent to 'ramos24@cruz2976.example' Take the following actions: delete the message	TRUE		

```
Get-InboxRule -Mailbox user@dom | Where-Object {$_.Name -eq '.'} | Remove-InboxRule -Force -Confirm:$false  
  
Get-InboxRule -Mailbox user@dom # verify gone
```

What Messages Were Accessed?



WHEN MAILITEMSACCESSED IS AVAILABLE

The answer you need

- Per-message InternetMessageId records
- Filter by known-malicious IP + SessionID for the exact list
- Cross-reference message trace for subject lines and senders
- 39-Search-UALMailItemsAccessedByUser.ps1
- Files: 38-Search-UALFileAccessedByUser.ps1

WHEN IT IS NOT - OR THROTTLED

Fall back to heuristics

- 'Too noisy to log' throttling stops recording at high volume
- Extensive other mailbox activity from the same session
- Dwell time inside the session
- Forged messages sent from the mailbox
- OAuth app granted access to the whole mailbox

The scope-of-disclosure question drives HIPAA, state AG, GDPR, PIPEDA notification determinations.

Scenario 2 - MailItemsAccessed Excerpt



Filter to the known-malicious IP + SessionID; extract InternetMessageIds

A	B	E	F	G	H	I	J	
AuditDataCreationTime	AuditDataOperation	AuditDataResultStatus	AuditDataWorkload	AuditDataUserId	AuditDataAADSessionId	AuditDataClientIpAddress	AuditDataClientInfoString	AuditDataExchangeId
2025-09-29 18:20	MailItemsAccessed	Succeeded	Exchange	betty20@contoso.com	Unavailable	137.27.96.204	Client=MSExchangeRPC	F
2025-09-29 18:04	MailItemsAccessed	Succeeded	Exchange	betty20@contoso.com	f8a0fb2c-c7ab-4fa8-86c5-431b627f7676	191.101.130.55	Client=OWA;Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleV	F
2025-09-29 17:35	MailItemsAccessed	Succeeded	Exchange	betty20@contoso.com	Unavailable	137.27.96.204	Client=MSExchangeRPC	F
2025-09-29 17:32	MailItemsAccessed	Succeeded	Exchange	betty20@contoso.com	Unavailable	137.27.96.204	Client=MSExchangeRPC	F
2025-09-29 17:34	MailItemsAccessed	Succeeded	Exchange	betty20@contoso.com	Unavailable	137.27.96.204	Client=REST;;	F
2025-09-29 17:35	MailItemsAccessed	Succeeded	Exchange	betty20@contoso.com	Unavailable	2603:10b6:510:995:1cfc:c5b4:fcc7:c427	Client=REST;Client=RESTSystem;;	F
2025-09-29 17:32	MailItemsAccessed	Succeeded	Exchange	betty20@contoso.com	Unavailable	2603:10b6:510:995:1cfc:c5b4:fcc7:c427	Client=REST;Client=RESTSystem;;	F
2025-09-29 17:31	MailItemsAccessed	Succeeded	Exchange	betty20@contoso.com	Unavailable	137.27.96.204	Client=REST;;	F
2025-09-29 17:28	MailItemsAccessed	Succeeded	Exchange	betty20@contoso.com	Unavailable	2603:10b6:510:995:1cfc:c5b4:fcc7:c427	Client=REST;Client=RESTSystem;;	F
2025-09-29 17:28	MailItemsAccessed	Succeeded	Exchange	betty20@contoso.com	Unavailable	137.27.96.204	Client=REST;;	F
2025-09-29 17:31	MailItemsAccessed	Succeeded	Exchange	betty20@contoso.com	f8a0fb2c-c7ab-4fa8-86c5-431b627f7676	191.101.130.55	Client=OWA;Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleV	F

```
PS> .\39-Search-UALMailItemsAccessedByUser.ps1 -UserPrincipalName paralegal@clientfirm.com `
      -StartDate (Get-Date).AddDays(-14)
```


Unified Audit Log: Notable Fields



Flatten the nested AuditData JSON before you can filter it

01 Why flatten

```
05-ProcessUnifiedAuditLogFlatten.ps1
```

Raw UAL packs the useful data into an AuditData JSON blob. Excel cannot filter it until each key becomes its own column.

02 Core fields

```
CreationTime · Operation · UserId · ClientIP · SessionID · Workload · ResultStatus
```

Operation plus ClientIP plus SessionId reconstructs who did what, from where, in which session.

03 Operation-specific

```
InternetMessageId · OperationCount · MailboxOwnerUPN · Parameters
```

MailItemsAccessed uses InternetMessageId and OperationCount. Watch for throttled 'Sync' operations.

Flatten first, filter second. Every UAL pivot in this module depends on it.

Pivot: Chronology + Topology



CHRONOLOGY - PROXIMITY IN TIME

Soon before / after

- Suspect sign-in at 02:13 - what else in that user's logs 02:13-02:45?
- Inbox rule created 02:18 - what sign-ins in the hour before?
- MailItemsAccessed burst 02:25 - any outbound 02:30-03:00?

TOPOLOGY - PROXIMITY IN SPACE

Same source / traits

- A malicious IP - whose logs else? (36-Search-UALActivityByIPAddress)
- A SessionID - what else in that session? (37-Search-UALActivityByUser)
- Other shared traits: ASN, UserAgent, device

Scenario 2 twist: the malicious IP authenticated to a **SECOND** account. Scope expanded.

Scenario category 2



Find the signal

01 Hydra just run – output is in folder

`Log files are all formatted as if straight off the tenant`

All three scenario categories use logs synthesized from real consulting engagements. Names and tenants are fictitious.

02 Process the output and analyze

`02 through 08 helper scripts`

Every answer is reachable from the provided CSVs. Same input, same findings.

03 This scenario adds

`Inbox rule + MailItemsAccessed + ???`

Scenario 2 builds on Scenario 1 – Start from sign-in logs and see where that leads.

Work with your neighbor. The goal is the pivot habit, not a race.

End-User Message Review



What actually reached and left the mailbox

01 Message trace

```
33-Get-UserMessageTrace.ps1
```

Inbound and outbound message metadata: sender, recipient, subject, timestamp, status. Reconstructs what the attacker received and sent.

02 Mailbox audit

```
34-Get-MailboxAuditLog.ps1
```

Per-mailbox record of actions (Create, SoftDelete, HardDelete, MailItemsAccessed (sometimes), SendAs) even when the sign-in trail is thin.

03 Cross-reference

```
Trace <> MailItemsAccessed <> inbox rule
```

Match InternetMessageIds from MailItemsAccessed to subject lines in the trace to name the exposed messages.

Message trace tells you what moved; mailbox audit tells you what was touched. Inbox rules tell you what was manipulated/targeted.

Content Search & Purge



44-Get-ExchangeMessageContentSearch.ps1

01 Create

`Compliance search by sender, subject, date`

Scope the search precisely before any destructive action.

02 Preview

`Review before acting`

Confirm the hit set is what you expect, per mailbox.

03 Export

`Capture for evidence & insurance`

Export the message set before purging anything. Must be done from web console.

04 Purge

`Remove tenant-wide`

Purge from recipient mailboxes only after export and sign-off.

Preserve vs purge: legal hold or law-enforcement need? Export only. Confirm destructive actions with the client.

05

MODULE 5 · 3:10 – 3:55 · 45 minutes · Scenario 3 · Previous + CAP & Reporting

Scope Expansion, Remediation, Reporting



The Scope-Expansion Loop



Every new IOC may drive another iteration, based on newly associated traits



Take notes for the report AS you go. Can be lists in TXT file. Don't wait until it's over.

Message Forwarding



Three places to check

01 Mailbox-level forwarding

```
20-Get-ForwardingSettings.ps1
```

Set via Set-Mailbox -ForwardingSmtpAddress / -ForwardingAddress. Visible to the user only in Outlook settings.

02 Inbox rule

```
17 / 19 - Search-MailboxSuspiciousRules / Get-AllInboxRules
```

Rule with ForwardTo or RedirectTo action. Often narrower than a mailbox-wide forward. Most common in BEC.

03 Transport rule (tenant-wide)

```
CrowdStrike CRT output · Get-TransportRule
```

Admin-level persistence. Requires admin-role compromise - a major red flag.

All three must be checked. A clean inbox-rule report does not mean forwarding is not happening. Consider hardening which disables external forwarding.

OAuth, Delegations, Federation



Three quiet places major compromises hide

01 OAuth Enterprise Applications

`22-Get-EnterpriseApplications.ps1`

Flag apps consented during the incident window. Known-bad: PerfectData Software, eM Client, new apps with mailbox or user.read.all scopes.

02 Mailbox delegations

`21-Get-MailboxPermissions.ps1`

Unexpected FullAccess, SendAs, SendOnBehalf grants added in the window enable quiet, persistent access.

03 Federation trust changes

`CrowdStrike CRT output (in Hydra sweep)`

New federated domains, trust changes, or token-signing mods are admin-level persistence and expand scope dramatically.

Scenario category 3



Full scope, remediation, and the report

01 Synthetic datasets

`Full log set for processing and review.`

02 This scenario adds

`OAuth, delegation, transport rule, admin persistence?, ?`

Scenario 3 expands scope beyond a single mailbox and drives the scope-expansion loop to closure.

03 The prize

`Accurate incident report`

First attendee to produce a correct, complete one-pager from the scenario data. Accuracy over speed.

Take report notes as you go. The write-up is part of the response, not an afterthought.

Immediate Remediation Checklist



Who doesn't love a good list?

- Lock every confirmed-affected account (sessions, sign-in, password).
- Revoke all refresh tokens for those users (Graph), or tenant-wide.
- Remove every malicious inbox rule found (take screenshots).
- Revoke consent for every malicious OAuth app (take screenshots).
- Remove any malicious transport rule (admin-role compromise trigger).
- Remove unauthorized mailbox delegations (FullAccess / SendAs / SendOnBehalf).
- Remove attacker-added authentication methods and devices.
- Release legitimate quarantined mail; keep phishing quarantined for evidence.
- Purge confirmed phishing tenant-wide via compliance search.

Verification is the remediation. If you didn't re-run Hydra, you didn't remediate - you just reacted.

Post-Incident Hardening



CONDITIONAL ACCESS (REPORT-ONLY FIRST)

92-Create-ConditionalAccessPolicies-P1

- MFA required for all users
- Block legacy authentication (POP, IMAP, SMTP basic)
- Geo-block countries the business never operates in
- Device compliance required for admin roles
- Block access from risky Ips and identified problem ASNs (VPN/TOR/hosting)
- See who would be blocked before blocking them
- Catch the scanner account using basic auth
- Find non-compliant devices
- Prioritize Secure Score by impact-to-effort
- Typical picks: MFA for admins, block legacy auth, enable audit log

Longer-term: phish-resistant MFA (FIDO2), token protection, risk-based CA, disable external forwarding, Defender for Office 365, security awareness training.

WHY REPORT-ONLY FIRST

93-Get-SecureScoreInformation

- Built-in Microsoft recommendations
- Requires higher license for automatic export
- Take top three recommendations

Home > Conditional Access - Policies	
Conditional Access - Policies	
Azure Active Directory	
+ New policy What If Got feedback?	
Interested in understanding the impact of the policies on a user sign-in? Check out the "What If" tool. →	
Policy Name	State
Baseline policy: Require MFA for admins (Preview)	Off
Baseline policy: End user protection (Preview)	Off
Baseline policy: Block legacy authentication (Preview)	Off
Baseline policy: Require MFA for Service Management (Preview)	Off
BLOCK - Legacy Authentication	On
BLOCK - High-Risk Sign-Ins	On
BLOCK - Countries not Allowed	On
BLOCK - Explicitly Blocked Cloud Apps	On
GRANT - Terms of Use	On
GRANT - Browser Access	On

When to Escalate



I Am Not A Lawyer - and neither are you (unless you are)

01 Cyber insurance carrier

Notify on any confirmed financial or data impact

Many policies require same-business-day notification. Don't let the client skip this - it's a coverage issue.

02 Breach coach / outside counsel

Any suspected PHI, PII, PCI, or privileged data

Any regulatory-notification or litigation risk. Bring counsel in before you write anything.

03 Law enforcement

FBI IC3 (ic3.gov) · U.S. Secret Service

USSS Financial Fraud Kill Chain can recover funds if wire fraud is reported fast (within 72 hours, >=\$50k, international, SWIFT recall).

You are the investigator; they are the decision-makers. Hand them facts, not legal conclusions.

Reporting



Different audiences, different documents

01 Investigation Report / One-page report (CLIENT)

Full technical record

Executive summary, timeline, IOC table, scope of access, recommendations. 3-5 pages for a typical BEC.

02 Attestation Letter (CARRIER, COUNSEL)

Short, formal, investigator-signed

What was found and done, on company letterhead. 1-3 pages. Supports the client's communications, not their legal determinations.

03 Internal Post-Mortem (YOUR TEAM)

Blameless

What went well, what didn't, where we got lucky. Action items with owners and dates. Not the client's document.

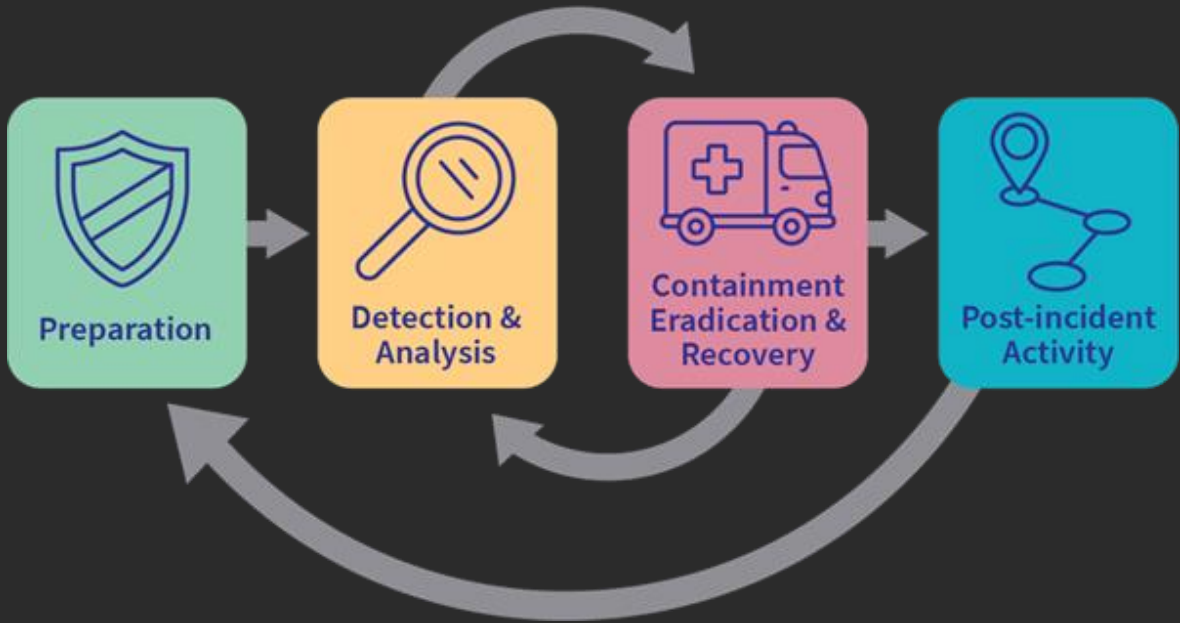
"That which can be measured can be managed." Blank templates for all three are in the workshop bundle.

The Playbook in One Slide



Zooming in on the NIST cycle, more or less... (whether Rev 2 or Rev 3)...

Cyber Incident Response Cycle



"Chronology is the first element of induction; topology is the second."

Using LLMs to Learn and Investigate



A useful second set of eyes; never the signer of record

01 Why this still matters

Patterns outlast the tooling

The scripting and macro thinking transfers to any log format. CSV and JSON will be with us for years, and someone must still sign off.

02 Where AI can help

Second-look log analysis · report drafting and review

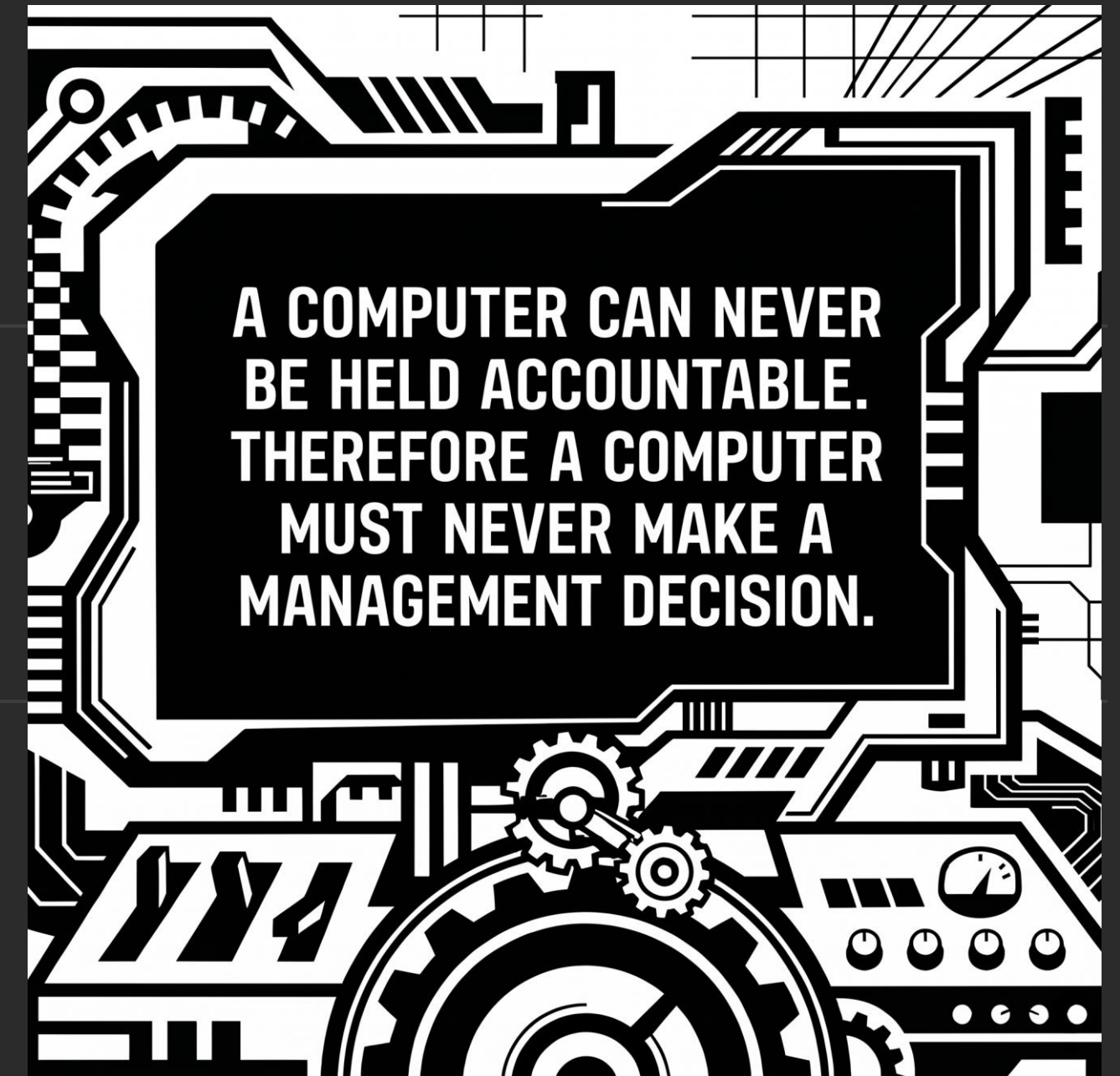
A repo-trained assistant can walk the response and draft reports.
Treat output as a lead to verify, not a conclusion.

03 Where it bites

Confidence you have not earned

Do not pass on certainty from a model which you cannot justify.
You own the deliverable and the attestation.

"You won't be replaced by AI... You will be replaced by someone using AI."



References & Further Reading



All links also in the walkthrough bibliography

Workshop repositories

github.com/bitpusher2k/DefConWorkshop
github.com/bitpusher2k/M365IRScripts
github.com/bitpusher2k/ExcelMacros

Microsoft official guidance

learn.microsoft.com/defender-office-365/responding-to-a-compromised-email-account
learn.microsoft.com/graph
learn.microsoft.com/powershell/exchange
O365 Management Activity API (UAL schema)

Threat intel & IOC (scenarios)

cybercorner.tech - PerfectData Software
cybercorner.tech - eM Client in BEC
fbi.gov - BEC common scams
ic3.gov - 2024 Internet Crime Report

Interoperable tooling

Invictus IR Microsoft Extractor Suite
CrowdStrike Reporting Tool for Azure (CRT)
CISA Sparrow · T0pCyber Hawk
DarkQuasar AzureHunter · PwC-IR extractors
randomaccess3.github.io/Awesome-BEC
o365reports.com · lazyadmin.nl · [EvotecIT](https://evotec.it)
Huntress rogue-apps list

Standards & frameworks

MITRE ATT&CK - Cloud / Office 365 matrix
NIST SP 800-61 Rev. 3 (2025) - Incident Response
CISA Cloud Security Technical Reference Arch.

Talks

Beryoza - (mis)Adventures in Azure Logs
Metcalf - Gone in 60 Seconds (Entra compromise)
PattersonCake - Anatomy of M365 BEC



The End

Thanks for joining me!



Questions, arguments, war stories?

github.com/bitpusher2k/DefConWorkshop

Technology · Martial Arts · Learning